

Deceiving the Defenses - The Workday Social Engineering Breach (2025)**Author :** Usha Priya Krishnasamy**Topic Area:** Cybersecurity ethics and dual-use risk in AI-assisted systems**Summary of the case:**

Workday, an AI-based cloud software provider for human resources and finance tasks, serves over 70 million users and 11,000 organizations, including more than 60% of Fortune 500 companies. In August 2025, it faced a data breach connected to a wider attack on Salesforce systems. The problem was detected on August 6, 2025, when hackers used Workday's link to Salesforce CRM through an AI chat tool, Salesloft's Drift. The cybercriminals ShinyHunters (UNC6040/UNC6240) and Scattered Spider (UNC3944), hacked into Salesloft/Drift's GitHub and AWS systems earlier that year, stealing OAuth tokens. These tokens helped them access Salesforce data without raising red flags, as they imitated normal user activity.

To get more access, hackers used social engineering, pretending to be IT or HR staff through calls and emails. They created an urgency, tricking Workday employees into approving new OAuth connections with an eight-digit code, using fake versions of tools like Salesforce's Data Loader or Drift. This allowed them to pull out large amounts of data from Workday's Salesforce system, including names, emails, phone numbers, and support case details. While main Workday customer databases stayed secure, the stolen data could lead to future phishing or blackmail attempts.

Workday's AI security system, which uses machine learning to spot odd patterns, missed the breach because the hackers' actions looked like regular admin tasks. It couldn't detect human pressure tactics. Workday took immediate action after the attack removing access, cancelling all Drift tokens, and checking vendors. Salesforce opted to take off the Drift from its AppExchange on August 20, 2025. This breach, which impacted more than 700 organizations including Google, Chanel, and Cisco, showed vulnerabilities in software chains and AI limits against human tricks. It calls for policies like the proposed Dual-Use Cybersecurity AI Accountability Act (DUCAA) to check integrated tools and prevent misuse.

Stakeholders and Impact:

1. **Employees:** As primary targets, Workday employees were deceived into granting OAuth access, exposing vulnerabilities in human-AI trust dynamics. This exposed their own contact data and potentially enabled further internal phishing. DUCAA's ethical audits and training requirements for dual-use risks would empower employees with tools to verify suspicious requests, promoting accountability and reducing coercion-based exploits in AI-assisted workflows.
2. **HR & Management Teams:** Responsible for overseeing AI-integrated HR processes, these teams dealt with disruptions in validating compromised support data, which could affect decision-making in payroll, onboarding, or performance analytics. The breach revealed gaps in third-party oversight, risking operational errors. DUCAA's governance framework, with mandates for transparent algorithm access and risk assessments, would

help these teams implement safeguards against repurposed integrations, ensuring ethical AI use aligned with organizational resilience.

3. **IT & Security Teams:** Tasked with detecting and responding to the intrusion, IT teams investigated the OAuth abuse and secured Salesforce connections post-breach. They faced challenges in monitoring for socially engineered anomalies that evaded AI heuristics. DUCAA's provisions for continuous "what-if" dual-use audits and anomaly contextualization would strengthen their defenses, enabling proactive identification of tool weaponization as seen with Drift's misuse.
4. **Customers/Clients:** Organisations using Workday's platforms faced indirect risks through exfiltrated contact data, which could contribute to targeted attacks or distort AI generated perspectives in their systems. For example, Fortune 500 firms could face phishing attacks using stolen details. DUCAA's transparency requirements and third-party vetting, based on the EU AI Act, safeguards clients through enforcement of ethical standards regarding dual-use technologies, to mitigate harms from interconnected SaaS ecosystems.
5. **Regulators & Compliance Bodies:** Agencies like CISA and the FBI collaborated with Workday on response efforts, enforcing standards amid the broader Salesforce campaign. The incident amplified calls for regulatory oversight of AI vulnerabilities. DUCAA's framework for honest logging and risk mitigation would support their mission, fostering systemic resilience against human-factor exploits in critical sectors.

Broader Issues in Technology and Ethics:

The Workday breach highlights ethical dilemmas where AI, social engineering, and dual-use risks in cybersecurity overlap. AI tools like Workday's behavior analytics improves efficiency but are not designed for deceptive exploits (customers relied on forcible authorizations of OAuth integrations without consideration for contextual intent analysis). This raises concerns about fairness where AI assumes benign user actions and informed consent, as employees under pressure unwittingly enable breaches, eroding accountability in automated systems.

At the heart of this is the dual-use dilemma: there are non-threatening applications like Drift, developed for conversational sales/HR support, that become weapons when bad actors acquire and refresh OAuth tokens through phishing, stealing data which can bias AI outcomes, sections, or other cascading attacks. Without ethical governance, opaque SaaS integrations prioritize innovation over transparency, damaging public trust and increasing bias in data about the financial and health sectors.

Related cases reinforce these issues. There was a significant breach of Snowflake in 2024 (Reuters, 2024) that was surprisingly similar to the Workday breach and involved ShinyHunters. The Attack of MGM Resorts (2023) by Scattered Spider (Bloomberg, 2023) using vishing to shut down systems is raising concern over readiness for human- AI defense. The 2020 SolarWinds hacking incident (NY Times, 2020) uses trusted software to breach security, just like Drift is exploiting technology. These incidents align with DUCAA's, by calling for ethical audits,

documentation requirements, and dual-use assessments and resonate with the EU AI Act (2024) to promote responsible use of AI and prevent misuse of connected technology.

Argument for Importance:

The Workday breach underscores why the Dual-Use Cybersecurity AI Accountability Act (DUCAA) must be made mandatory across all AI-integrated systems to fix serious ethical and oversight gaps in cybersecurity. It would require clear AI intent documentation, continuous third-party audits, and "what-if" dual-use risk assessments, to prevent misuse of tools like Data Loader or Drift through fake OAuth access and social engineering. DUCAA should mandate strict vendor contracts that limit data permissions and stop unauthorized data sharing. In addition, it must make multi-factor authentication (MFA) required for all OAuth connections to block phishing from copied or fake apps that access CRM data.

By demanding regular reviews of how humans and tools can be exploited together, this policy would greatly cut down on vishing and impersonation threats, protecting millions in healthcare, finance, and critical sectors from targeted phishing or biased AI results. The case supports proposed DUCAA's call for vendor accountability and ethical audits before deployment turning AI from an exploitable weakness into a strong defense and helping prevent future risks in unregulated systems.

References

Admin by Request. (2025, August 19). *Workday falls victim to the ShinyHunters*

Salesforce attack spree. Admin by Request.

<https://www.adminbyrequest.com/en/blogs/workday-falls-victim-to-the-shinyhunters-salesforce-attack-sprees>

CTO Digital. (2025, August 18). *HR giant Workday says hackers stole personal data in recent breach*. TechCrunch. <https://techcrunch.com/2025/08/18/hr-giant-workday-says-hackers-stole-personal-data-in-recent-breach/>

Cybersecurity Dive. (2025, August 18). *Hackers target Workday in social engineering attack*. Cybersecurity Dive. <https://www.cybersecuritydive.com/news/hackers-target-workday-in-social-engineering-attack/758095/>

DoControl. (2025, August 22). *Workday breach: What happened and what we can learn*. DoControl.

<https://www.docontrol.io/blog/workday-breach>

MLQ AI. (2025, August 21). *Workday discloses data breach via third-party CRM links to recent Salesforce social engineering campaigns*. MLQ AI. <https://mlq.ai/news/workday-discloses-data-breach-via-third-party-crm-links-to-recent-salesforce-social-engineering-campaigns/>

Obsidian Security. (2025, August 25). *ShinyHunters and Scattered Spider: A merger of chaos in the 2025 Salesforce attacks*. Obsidian Security.

<https://www.obsidiansecurity.com/blog/shinyhunters-and-scattered-spider-a-merger-of-chaos-in-the-2025-salesforce-attacks>

PTech Partners. (2025, August 26). *The Workday data breach: How this latest attack in the Salesforce campaign impacts you*. PTech Partners.

<https://www.ptechpartners.com/2025/08/26/the-workday-data-breach-how-this-latest-attack-in-the-salesforce-campaign-impacts-you/>

Salesforce DevOps. (2025, August 17). *Salesforce customers fall victim as ShinyHunters and Scattered Spider join forces*. Salesforce DevOps.

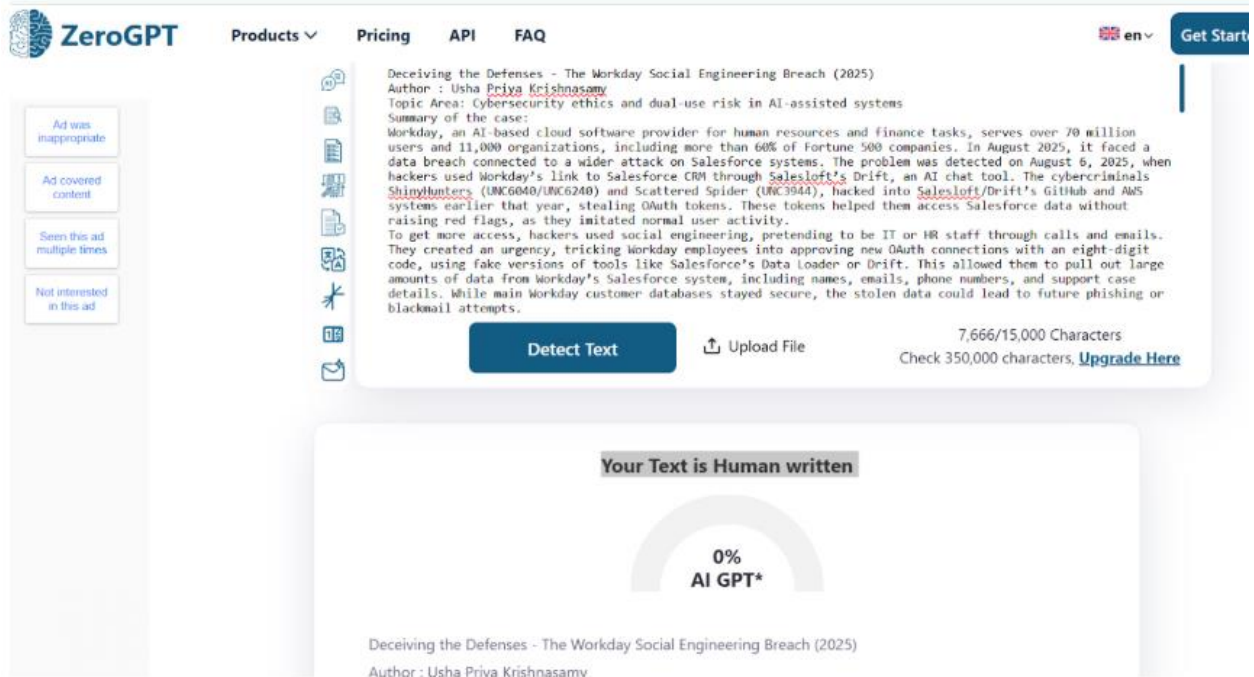
<https://salesforcedevops.net/index.php/2025/08/17/salesforce-customers-fall-victim-as-shinyhunters-and-scattered-spider-join-forces/>

Workday. (2025, August 18). *Workday's response to Salesloft Drift security incident*.

Workday Blog. <https://blog.workday.com/en-us/workdays-response-salesloft-drift-security-incident.html>

Appendix on AI Use:

I have not used Generative AI (GenAI) for this case study.



The screenshot shows the ZeroGPT website interface. The top navigation bar includes the ZeroGPT logo, links for Products, Pricing, API, and FAQ, a language selector set to 'en', and a 'Get Started' button. On the left side, there are four buttons for ad feedback: 'Ad was inappropriate', 'Ad covered content', 'Seen this ad multiple times', and 'Not interested in this ad'. The main content area displays a text analysis result for a document titled 'Deceiving the Defenses - The Workday Social Engineering Breach (2025)' by Usha Priya Krishnasamy. The text area contains a summary of the case, detailing a social engineering breach at Workday in August 2025. Below the text, there are buttons for 'Detect Text' and 'Upload File'. To the right of these buttons, it shows '7,666/15,000 Characters' and a link to 'Check 350,000 characters, Upgrade Here'. At the bottom, a large white box displays the result: 'Your Text is Human written' with a '0% AI GPT*' score, accompanied by a semi-circular progress indicator.

ZeroGPT Products Pricing API FAQ en Get Started

Ad was inappropriate
Ad covered content
Seen this ad multiple times
Not interested in this ad

Deceiving the Defenses - The Workday Social Engineering Breach (2025)
Author : Usha Priya Krishnasamy
Topic Area: Cybersecurity ethics and dual-use risk in AI-assisted systems
Summary of the case:
Workday, an AI-based cloud software provider for human resources and finance tasks, serves over 70 million users and 11,000 organizations, including more than 60% of Fortune 500 companies. In August 2025, it faced a data breach connected to a wider attack on Salesforce systems. The problem was detected on August 6, 2025, when hackers used Workday's link to Salesforce CRM through Salesforce's Drift, an AI chat tool. The cybercriminals ShinyHunters (URC6040/URC6240) and Scattered Spider (URC3944), hacked into Salesforce/Drift's GitHub and AaS systems earlier that year, stealing OAuth tokens. These tokens helped them access Salesforce data without raising red flags, as they imitated normal user activity.
To get more access, hackers used social engineering, pretending to be IT or HR staff through calls and emails. They created an urgency, tricking Workday employees into approving new OAuth connections with an eight-digit code, using fake versions of tools like Salesforce's Data Loader or Drift. This allowed them to pull out large amounts of data from Workday's Salesforce system, including names, emails, phone numbers, and support case details. While main Workday customer databases stayed secure, the stolen data could lead to future phishing or blackmail attempts.

Detect Text Upload File 7,666/15,000 Characters
Check 350,000 characters, Upgrade Here

Your Text is Human written

0% AI GPT*

Deceiving the Defenses - The Workday Social Engineering Breach (2025)
Author : Usha Priya Krishnasamy